Email Security Audit Report

Phishing & spoofing analysis of raw e-mail headers and body content

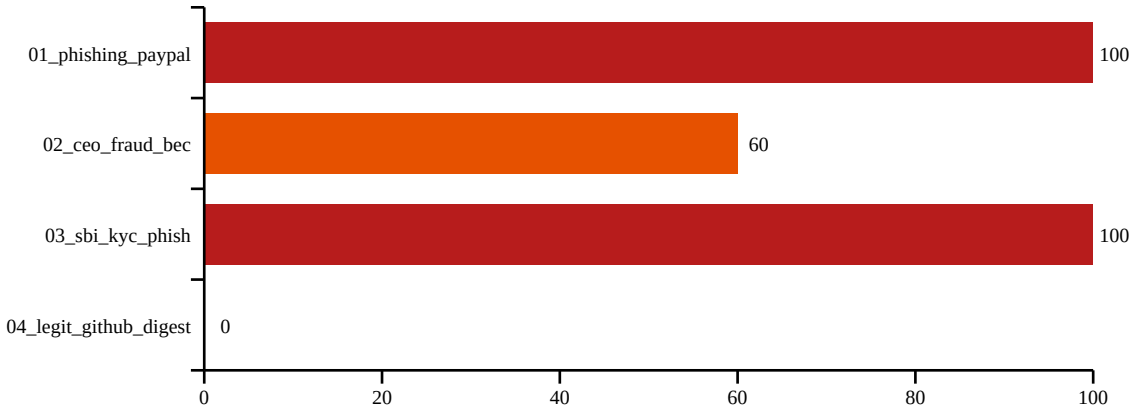
Generated 06 October 2026, 14:05 | Tool: email_analyzer.py v1.0.0 | Messages analysed: 4

1. Executive summary

4 messages were scanned. **3** were classified HIGH or CRITICAL risk (likely phishing or spoofing), **0** as MEDIUM, and **1** as LOW. The scoring combines header authentication (SPF / DKIM / DMARC), identity spoofing signals (From / Return-Path / Reply-To / display name), mail-routing anomalies (Received chain), link and domain analysis, lure language, and attachments.

#	Message	Sender domain	Score	Verdict
1	01_phishing_paypal.eml	paypa1-secure-login.com	**100/100**	**CRITICAL** - Phishing or spoofing - do not interact
2	02_ceo_fraud_bec.eml	gmail.com	**60/100**	**HIGH** - Likely phishing / spoofed
3	03_sbi_kyc_phish.eml	sbi-kyc-update.xyz	**100/100**	**CRITICAL** - Phishing or spoofing - do not interact
4	04_legit_github_digest.eml	github.com	**0/100**	**LOW** - Likely legitimate

Risk score by message (0 = benign, 100 = certain phishing)



2. Methodology

Each message is parsed with Python's `email` library and analysed in four stages. Every triggered check adds weighted points; the total is capped at 100. No network lookups are made and no URLs are ever visited.

Stage	What is inspected	Typical points
Header parsing	From vs Return-Path vs Reply-To domain alignment; display-name impersonation of brands or executives; free-mail senders; missing/odd Message-ID and Date; look-alike (homoglyph / typosquat) sender domains.	3 - 25
SPF / DKIM / DMARC	Authentication-Results and Received-SPF values; DKIM d= domain alignment with the visible sender.	fail 18-20, softfail 10, none 5-6
Received chain	Hop count, origin IP, generic HELO names, HELO vs reverse-DNS mismatch, out-of-order timestamps, Date skew.	3 - 8
Links and forms	Link text vs real target, raw-IP hosts, user@host tricks, shorteners, brand-in-subdomain, punycode, abused TLDs, http links, password forms.	5 - 25
Lure language	Urgency, threats, credential requests, financial/BEC phrasing, rewards, generic greetings; bonus for the urgency+threat+credential combination.	4 - 18 per category
Attachments	Executables, double extensions, macro documents, HTML and archives.	6 - 25

Risk bands

Score	Band	Meaning
0 - 19	LOW	Likely legitimate
20 - 44	MEDIUM	Suspicious - manual review advised
45 - 69	HIGH	Likely phishing / spoofed
70 - 100	CRITICAL	Phishing or spoofing - do not interact

3. Detailed findings

3.1 01_phishing_paypal.eml

Risk score **100/100** - **CRITICAL** (Phishing or spoofing - do not interact)

Main drivers: Sender domain: Homoglyph / look-alike domain; Link text shows one domain but points to another; Double file extension.

From	PayPal Support <security-alert@paypa1-secure-login.com>
Return-Path	<bounce@mailer.bulk-sender.top>
Reply-To	recovery.desk@gmail.com
Subject	URGENT: Your account has been suspended - verify within 24 hours!
SPF / DKIM / DMARC	fail / none / fail
DKIM signing domain(s)	none
Relay hops / origin IP	2 / 203.0.113.45
Attachments	Invoice_4471.pdf.exe

Severity	Category	Finding	Pts
CRITICAL	Header	**Sender domain: Homoglyph / look-alike domain** 'paypa1-secure-login.com' imitates 'paypal' using look-alike characters. `paypa1-secure-login.com`	+25
CRITICAL	Link	**Link text shows one domain but points to another** Reader sees 'www.paypal.com' but the click goes to 'paypal.com.account-verify.top'. `hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]113[.]45/collect`	+25
CRITICAL	Attachment	**Double file extension** Disguises an executable as a document. `Invoice_4471.pdf.exe`	+25
CRITICAL	Authentication	**SPF result: fail** SPF did not validate (fail); the sending server is not proven to be authorised for this domain. `spf=fail`	+20
CRITICAL	Authentication	**DMARC result: fail** DMARC did not validate (fail); the sending server is not proven to be authorised for this domain. `dmarc=fail`	+20
CRITICAL	Link	**Link points to a raw IP address** Legitimate brands link to named domains, not IP addresses. `hxxp://203[.]0[.]113[.]45/update[.]php`	+20
CRITICAL	Content	**Password field embedded in the e-mail** Real services never ask for passwords inside an e-mail body.	+20
HIGH	Header	**Display name impersonates a known brand** Display name mentions 'paypal' but the address domain is 'paypa1-secure-login.com'. `Display name "PayPal Support"`	+18
HIGH	Link	**Link domain: Brand name used in subdomain of unrelated domain** 'paypal.com.account-verify.top' puts 'paypal' in front of the real domain 'account-verify.top'. `hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]113[.]45/collect`	+18
HIGH	Content	**Threat / fear language** 3 distinct indicator(s) found. `"account has been suspended"; "unauthorized access"; "permanently closed"`	+16
HIGH	Header	**Reply-To points to a different domain** Replies are silently redirected away from the apparent sender. `From=paypa1-secure-login.com Reply-To=gmail.com`	+12
HIGH	Content	**Credential harvesting language** 2 distinct indicator(s) found. `"verify your account"; "update your payment"`	+12

Severity	Category	Finding	Pts
MEDIUM	Content	**Urgency language** 3 distinct indicator(s) found. `"urgent"; "immediately"; "within 24 hours"`	+11
MEDIUM	Content	**Embedded form submits to an external host** Form data is posted to a server that is not the sender's domain. `hxxp://203[.]0[.]113[.]45/login[.]php`	+10
MEDIUM	Header	**Return-Path domain differs from From domain** Envelope sender is 'mailer.bulk-sender.top' but the visible sender is 'paypa1-secure-login.com'. Legitimate bulk senders do this too, but it is a classic spoofing signal. `From=paypa1-secure-login.com Return-Path=mailer.bulk-sender.top`	+8
MEDIUM	Header	**Return-Path domain: High-abuse top-level domain** '.top' is heavily used for throw-away phishing domains. `mailer.bulk-sender.top`	+8
MEDIUM	Link	**Link domain: High-abuse top-level domain** '.top' is heavily used for throw-away phishing domains. `hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]113[.]45/collect`	+8
MEDIUM	Link	**Open-redirect style parameter** The URL embeds another URL, often used to launder a malicious destination. `hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]113[.]45/collect`	+8
MEDIUM	Link	**URL shortener hides the destination** Short links prevent inspection of where the click really leads. `hxxps://bit[.]ly/3xYz123`	+8
MEDIUM	Content	**Classic phishing combination** Urgency + threat + credential request together is the signature pattern of account-takeover phishing.	+8
MEDIUM	Authentication	**DKIM result: none** DKIM signature check returned 'none'. `dkim=none`	+6
LOW	Routing	**Origin hop uses a generic / non-FQDN HELO name** First hop identifies itself as 'localhost', typical of scripted mailers rather than real mail servers. `localhost`	+5
LOW	Link	**Unencrypted (http) link** Credentials entered here would travel in clear text. `hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]113[.]45/collect`	+5
LOW	Link	**Unencrypted (http) link** Credentials entered here would travel in clear text. `hxxp://203[.]0[.]113[.]45/update[.]php`	+5
LOW	Content	**Generic greeting language** 1 distinct indicator(s) found. `"dear customer"`	+4

Extracted URLs (defanged - safe to read, not clickable)

URL	Visible text	Flags
`hxxp://paypal[.]com[.]account-verify[.]top/signin?redirect=http://203[.]0[.]1...`	https://www.paypal.com/myaccount/verify	Link domain: High-abuse top-level domain; Link domain: Brand name used in subdomain of unrelated domain; Unencrypted (http) link; Open-redirect style parameter; Link text shows one domain but points to another
`hxxp://203[.]0[.]113[.]45/update[.]php`	Update Now	Link points to a raw IP address; Unencrypted (http) link
`hxxps://bit[.]ly/3xYz123`	https://bit.ly/3xYz123	URL shortener hides the destination
`hxxps://www[.]paypal[.]com/myaccount/verify`	-	none

3.2 02_ceo_fraud_bec.eml

Risk score **60/100** - **HIGH** (Likely phishing / spoofed)

Main drivers: Authority/role name sent from a free-mail account; Impersonation / BEC language; Reply-To points to a different domain.

From	Rahul Menon - CEO <rahul.menon.ceo@gmail.com>
Return-Path	<rahul.menon.ceo@gmail.com>
Reply-To	Rahul Menon <r.menon.office@proton.me>
Subject	Quick task - urgent
SPF / DKIM / DMARC	pass / pass / pass
DKIM signing domain(s)	gmail.com
Relay hops / origin IP	1 / 198.51.100.71
Attachments	none

Severity	Category	Finding	Pts
HIGH	Header	**Authority/role name sent from a free-mail account** Executives and support teams rarely write from public webmail; typical of business-e-mail-compromise (BEC) fraud. `"Rahul Menon - CEO" <rahul.menon.ceo@gmail.com>`	+15
HIGH	Content	**Impersonation / BEC language** 6 distinct indicator(s) found. `"are you available"; "keep this confidential"; "can't take calls"; "in a meeting"; "quick task"`	+14
HIGH	Header	**Reply-To points to a different domain** Replies are silently redirected away from the apparent sender. `From=gmail.com Reply-To=proton.me`	+12
MEDIUM	Content	**Urgency language** 3 distinct indicator(s) found. `"urgent"; "immediately"; "as soon as possible"`	+11
MEDIUM	Content	**Financial lure language** 3 distinct indicator(s) found. `"wire transfer"; "gift cards"; "new vendor"`	+8
INFO	Authentication	**SPF result: pass** SPF validated. `spf=pass`	0
INFO	Authentication	**DKIM result: pass** DKIM validated. `dkim=pass`	0
INFO	Authentication	**DMARC result: pass** DMARC validated. `dmarc=pass`	0

3.3 03_sbi_kyc_phish.eml

Risk score **100/100** - **CRITICAL** (Phishing or spoofing - do not interact)

Main drivers: Sender domain: Brand name embedded in unrelated domain; Credential harvesting language; Display name impersonates a known brand.

From	SBI Alerts <alerts@sbi-kyc-update.xyz>
Return-Path	<alerts@sbi-kyc-update.xyz>
Reply-To	-
Subject	Final notice: KYC expired - account will be blocked today
SPF / DKIM / DMARC	softfail / none / none
DKIM signing domain(s)	none
Relay hops / origin IP	1 / 198.51.100.23
Attachments	none

Severity	Category	Finding	Pts
CRITICAL	Header	**Sender domain: Brand name embedded in unrelated domain** 'sbi-kyc-update.xyz' contains 'sbi' but is not an official sbi domain. `sbi-kyc-update.xyz`	+20
CRITICAL	Content	**Credential harvesting language** 4 distinct indicator(s) found. `"update your kyc"; "re-activate"; "otp"; "share your"`	+20
HIGH	Header	**Display name impersonates a known brand** Display name mentions 'sbi' but the address domain is 'sbi-kyc-update.xyz'. `Display name "SBI Alerts"`	+18
HIGH	Link	**Link domain: Brand name used in subdomain of unrelated domain** 'onlinesbi.com.kyc-update.xyz' puts 'sbi' in front of the real domain 'kyc-update.xyz'. `hxxp://onlinesbi[.]com[.]kyc-update[.]xyz/login`	+18
HIGH	Content	**Urgency language** 4 distinct indicator(s) found. `"immediately"; "final notice"; "last chance"; "expired"`	+14
HIGH	Content	**Threat / fear language** 2 distinct indicator(s) found. `"account will be blocked"; "will be blocked"`	+12
MEDIUM	Authentication	**SPF result: softfail** SPF did not validate (softfail); the sending server is not proven to be authorised for this domain. `spf=softfail`	+10
MEDIUM	Header	**Sender domain: High-abuse top-level domain** '.xyz' is heavily used for throw-away phishing domains. `sbi-kyc-update.xyz`	+8
MEDIUM	Link	**Link domain: High-abuse top-level domain** '.xyz' is heavily used for throw-away phishing domains. `hxxp://onlinesbi[.]com[.]kyc-update[.]xyz/login`	+8
MEDIUM	Content	**Classic phishing combination** Urgency + threat + credential request together is the signature pattern of account-takeover phishing.	+8
MEDIUM	Authentication	**DKIM result: none** DKIM signature check returned 'none'. `dkim=none`	+6
LOW	Authentication	**DMARC result: none** DMARC did not validate (none); the sending server is not proven to be authorised for this domain. `dmarc=none`	+5
LOW	Routing	**Origin hop uses a generic / non-FQDN HELO name** First hop identifies itself as 'unknown', typical of scripted mailers rather than real mail servers. `unknown`	+5

Severity	Category	Finding	Pts
LOW	Link	**Unencrypted (http) link** Credentials entered here would travel in clear text. `hxxp://onlinesbi[.]com[.]kyc-update[.]xyz/login`	+5
LOW	Content	**Financial lure language** 1 distinct indicator(s) found. `"kyc"`	+4
LOW	Content	**Generic greeting language** 1 distinct indicator(s) found. `"dear customer"`	+4
LOW	Content	**Excessive exclamation marks** Pressure tactic.	+3

Extracted URLs (defanged - safe to read, not clickable)

URL	Visible text	Flags
`hxxp://onlinesbi[.]com[.]kyc-update[.]xyz/login`	-	Link domain: High-abuse top-level domain; Link domain: Brand name used in subdomain of unrelated domain; Unencrypted (http) link

3.4 04_legit_github_digest.eml

Risk score **0/100** - **LOW** (Likely legitimate)

From	GitHub <notifications@github.com>
Return-Path	<notifications@github.com>
Reply-To	-
Subject	[GitHub] Your weekly digest
SPF / DKIM / DMARC	pass / pass / pass
DKIM signing domain(s)	github.com
Relay hops / origin IP	2 / 192.0.2.10
Attachments	none

Severity	Category	Finding	Pts
INFO	Authentication	**SPF result: pass** SPF validated. `spf=pass`	0
INFO	Authentication	**DKIM result: pass** DKIM validated. `dkim=pass`	0
INFO	Authentication	**DMARC result: pass** DMARC validated. `dmarc=pass`	0

Extracted URLs (defanged - safe to read, not clickable)

URL	Visible text	Flags
`hxxps://github[.]com/example-org/portfolio-site`	View repository	none

4. Recommendations

1. Quarantine HIGH / CRITICAL messages. Block or quarantine, do not open links or attachments, and report the sender domain and URLs to the security team and the impersonated brand.

2. Enforce sender authentication. Publish SPF and DKIM for your own domains and move DMARC to p=quarantine, then p=reject, so spoofed mail claiming to be you is rejected.

3. Verify money requests out-of-band. Payment, gift-card or bank-detail changes must be confirmed by a phone call to a known number - this defeats BEC fraud that passes SPF/DKIM from free-mail accounts.

4. Distrust display names. Always inspect the real address and Reply-To; configure the mail client to show full sender addresses and tag external senders.

5. Harden accounts. Use MFA / passkeys so a stolen password alone is not enough, and never type credentials or OTPs into pages reached from e-mail links.

6. Contain attachments and links. Sandbox or strip executables, macro documents and HTML attachments; rewrite and detonate URLs at the gateway.

7. Train and make reporting easy. Run phishing simulations and provide a one-click 'Report phishing' button.

5. Limitations

- Heuristic and offline: no DNS, WHOIS, domain-age or URL-reputation lookups; a determined attacker using a clean, aged domain can score lower than the true risk.

- Authentication-Results / Received-SPF are trusted as written. They are only reliable when added by your own receiving MTA; headers injected earlier in the chain can be forged.

- Return-Path mismatches and non-aligned DKIM also occur on legitimate bulk mail; those checks are deliberately low-weighted to limit false positives.

- The sample messages in this report are synthetic (fake domains, documentation IP ranges) and were created for demonstration. Weights should be tuned against real mail before production use.